INSTITUTO FEDERAL
São Paulo

Segurança e restrição de conteúdos com sessões

PROF. DR. EDER PANSANI
epansani@gmail.com / epansani@ifsp.edu.br

Conteúdo da aula

INSTITUTO FEDERAL
São Paulo

O objetivo deste conteúdo é apresentar de forma prática, usando exemplos quais os conceitos e qual a **lógica** da **restrição de conteúdos** e implementação de **segurança** em **aplicações PHP usando sessões**.

INSTITUTO FEDERAL
São Paulo

Introdução

Introdução

Como já foi discutido, em aplicações web reais, nem todo conteúdo deve ser público.

Introdução

INSTITUTO FEDERAL
São Paulo

Exemplos:

- Área administrativa
- Dados pessoais do usuário
- Funcionalidades exclusivas

Introdução

Surge então a necessidade de:

1) Identificar o usuário
2) Controlar o que ele pode acessar

Introdução

INSTITUTO FEDERAL
São Paulo

Relembrando:

O protocolo HTTP é ***stateless***, ou seja:

Cada requisição é <u>independente</u> e o <u>servidor não sabe quem é o usuário</u>.

Introdução

INSTITUTO FEDERAL
São Paulo

Isso significa que:

- Após um login, o servidor não lembra automaticamente que você está autenticado
- Precisamos de um mecanismo para manter esse estado

Introdução

É aqui que entram as sessões

$_SESSION

INSTITUTO FEDERAL
São Paulo

Autenticação

Autenticação

O que é autenticação?

Autenticação é o **processo de verificar se o usuário é quem ele diz ser**.

Autenticação

INSTITUTO FEDERAL
São Paulo

Fluxo típico:

- Usuário envia nome de usuário (*login*) e senha
- Sistema valida os dados
  - Se válido → cria uma sessão
  - Se inválido → retorna erro

Autenticação

Essa sessão passa a **representar o usuário no sistema**.

Autenticação

INSTITUTO FEDERAL
São Paulo

Como isso funciona na prática?

Após validar os dados de autenticação, armazenamos um identificador do usuário. Algo como:

```
1  <?php
2
3  $_SESSION['usuario'] = $usuario;
4
5  ?>
```

Autenticação

INSTITUTO FEDERAL
São Paulo

A partir desse momento:

- O sistema reconhece o usuário em outras páginas
- É possível implementar o controle de acesso com base nisso

Autenticação

INSTITUTO FEDERAL
São Paulo

Exemplo

```php
<?php
session_start();

if ($usuario == "epansani" && $senha == "1a6$") {
    $_SESSION['usuario'] = $usuario;
    header("Location: index.php");
    exit;
} else {
    echo "Usuário ou senha inválidos";
}

```

```php
<?php
session_start();

if ($usuario == "epansani" && $senha == "1a6$") {
    $_SESSION['usuario'] = $usuario;
    header("Location: index.php");
    exit;
} else {
    echo "Usuário ou senha inválidos";
}

```

Autenticação

INSTITUTO FEDERAL
São Paulo

Neste exemplo estamos:

- Validando credenciais
- Criando a sessão
- Redirecionando o usuário

Autenticação

INSTITUTO FEDERAL
São Paulo

Importante!

Este exemplo tem objetivos didáticos, por isso a senha está direto no código, **isso não deve ser feito**.

Em produção deve-se usar um banco de dados e senha criptografada.

Autenticação

INSTITUTO FEDERAL
São Paulo

Tratamento de erros

É importante lidar com situações comuns como:

- Usuário não encontrado
- Senha incorreta
- Campos vazios

```php
<?php
session_start();

if (empty($usuario) || empty($senha)) {
    echo "Preencha todos os campos";
}

if ($usuario == "epansani") {
    if ($senha == "1a6$") {
        $_SESSION['usuario'] = $usuario;
        header("Location: index.php");
        exit;
    } else {
        echo "Senha inválida";
    }
} else {
    echo "Usuário não localizado";
}
```

INSTITUTO FEDERAL
São Paulo

Autenticação

Outra boa prática é impedir que o usuário já autenticado volte a acessar o formulário de autenticação.

Isso pode ser feito com um **redirecionamento**.

Autenticação

INSTITUTO FEDERAL
São Paulo

Veja um exemplo disso:

```php
<?php
// Isso deve ser colocado na página
// do formulário de autenticação
session_start();

if (isset($_SESSION['usuario'])) {
    header("Location: index.php");
    exit;
}
```

Autenticação

Como este código irá redirecionar o usuário, guiando o fluxo da aplicação, é preciso **mostrar uma mensagem**, informando **o que está acontecendo**, algo do tipo:

"Você já está autenticado"

Autenticação

Existe um mecanismo de **mensagens temporárias**, também conhecidas como "***flash messages***", que consiste no uso de <u>enviar algo de uma página para outra usando a sessão</u>.

Autenticação

INSTITUTO FEDERAL
São Paulo

Veja:

```php
<?php
// Isso deve ser colocado na página
// do formulário de autenticação
session_start();

if (isset($_SESSION['usuario'])) {
    $_SESSION['mensagem'] = "Você já está autenticado.";
    header("Location: index.php");
    exit;
}

```

```php
<?php
// Isso deve ser colocado na página
// do formulário de autenticação
session_start();

if (isset($_SESSION['usuario'])) {
    $_SESSION['mensagem'] = "Você já está autenticado.";
    header("Location: index.php");
    exit;
}

```

Autenticação

- Testa se o usuário já está autenticado
- Em caso positivo:
  - Salva uma mensagem na sessão
  - Redireciona para a página inicial

Autenticação

INSTITUTO FEDERAL
São Paulo

E depois na página inicial:

```php
<?php
// Página inicial (index)
session_start();

if (isset($_SESSION['mensagem'])) {
    echo $_SESSION['mensagem'];
    unset($_SESSION['mensagem']); // remove após exibir
}

```

Autenticação

Essa mensagem:

- Existe apenas por uma requisição
- É exibida uma vez
- Depois é removida

Autenticação

INSTITUTO FEDERAL
São Paulo

Por que é preciso remover a mensagem?

Porque se não ela vai continuar aparecendo “para sempre”, deixando assim de ser temporária.

Autenticação

INSTITUTO FEDERAL
São Paulo

Quando usar isso?

- “Login realizado com sucesso”
- “Usuário ou senha inválidos”
- “Você precisa estar autenticado”
- “Logout realizado”

Autenticação

Com isso contatamos que a **sessão não serve só para armazenar usuário**, ela também **pode ser usada para comunicação entre páginas**

INSTITUTO FEDERAL
São Paulo

Utilizando as sessões

Utilizando as sessões

INSTITUTO FEDERAL
São Paulo

Agora que já sabemos como criar uma sessão, podemos utilizá-la para **proteger páginas** ou **trechos**, criando assim uma **interface dinâmica**.

Utilizando as sessões

INSTITUTO FEDERAL
São Paulo

Por exemplo, para ter um **menu dinâmico**, capaz de mostrar opções diferentes dependendo da autenticação do usuário, botões “Entrar” e “Sair” por exemplo.

Utilizando as sessões

INSTITUTO FEDERAL
São Paulo

```php
<?php

if (isset($_SESSION['usuario'])) {
    echo "<a href='restrito.php'>Área restrita</a>";
    echo "<a href='logout.php'>Sair</a>";
} else {
    echo "<a href='login.php'>Login</a>";
}

```

Utilizando as sessões

INSTITUTO FEDERAL
São Paulo

Outra coisa comum é impedir o acesso a determinadas páginas a utilizadores não autenticados. Isso torna a página “protegida”, sendo possível de ser acessada só por usuários autenticados.

Utilizando as sessões

INSTITUTO FEDERAL
São Paulo

Veja um exemplo

```php
<?php
session_start();

if (!isset($_SESSION['usuario'])) {
    $_SESSION['mensagem'] = "Você está tentando acessar conteúdo restrito";
    header("Location: login.php");
    exit;
}
```

Utilizando as sessões

INSTITUTO FEDERAL
São Paulo

Isso impede acesso direto via URL.

Considerando que os usuários não terão acesso aos links (ou botões) que levam a essa página SE ele não puder acessá-la.

Utilizando as sessões

É possível ainda restringir o acesso, a visualização a determinados trechos de páginas a usuários autenticados.

Veja um exemplo disso:

Utilizando as sessões

INSTITUTO FEDERAL
São Paulo

```php
<?php
session_start();

if (isset($_SESSION['usuario'])) {
    echo "Conteúdo que deve ser mostrado só";
    echo "para usuários autenticados.";
}
```

Encerrando a sessão (sair)

Encerrando a sessão (sair)

Por fim, é preciso ter uma opção (link/botão) para sair, para encerrar a sessão e “deslogar” um usuário do sistema.

Um exemplo de código que faz isso pode ser visto a seguir

Encerrando a sessão (sair)

INSTITUTO FEDERAL
São Paulo

```php
<?php
session_start();
session_destroy();
header("Location: index.php");
exit;

```

Encerrando a sessão (sair)

INSTITUTO FEDERAL
São Paulo

Note que é preciso usar um ***session_start()*** antes de destruir a sessão.

```php
<?php
session_start();
session_destroy();
header("Location: index.php");
exit;
```

Encerrando a sessão (sair)

Isso acontece porque a sessão no PHP não fica automaticamente disponível.

Encerrando a sessão (sair)

O que o ***session_destroy()*** faz?

Ele **destrói a sessão que está ativa no momento**.

Encerrando a sessão (sair)

INSTITUTO FEDERAL
São Paulo

Enquanto isso o ***session_start():***

- Lê o cookie de sessão do navegador
- Localiza os dados da sessão no servidor
- Carrega esses dados para uso no script

Depois disso você tem acesso à sessão atual.

Encerrando a sessão (sair)

Sendo assim, **se você não iniciou a sessão antes**, **não existe "sessão ativa" para destruir**.

INSTITUTO FEDERAL
São Paulo

Conclusão

Conclusão

INSTITUTO FEDERAL
São Paulo

Boas práticas

- Sempre usar session_start()
- Usar exit após header
- Separar lógica de autenticação

Conclusão

Com sessões conseguimos:

- Manter o estado do usuário
- Controlar autenticação
- Restringir acesso
- Criar aplicações mais seguras

Conclusão

Esse é o primeiro passo para construção de aplicações reais, que utilizam bancos de dados e requerem controle de permissões e restrição de conteúdos (ou páginas).

INSTITUTO FEDERAL
São Paulo

Dúvidas?

Perguntas?

Sugestões?